UNITÉ D'ÉTUDE SEPT : ANALYSE DU CADRE INFORMATIQUE ET DES DONNÉES

7.1	*Cadres de contrôle informatique et Organisation internationale de normalisation (ISO)*	*2*
7.2	*Aspects du traitement automatisé de l'information .....*	*11*
7.3	*Contrôles IT .....*	*13*
7.4	*Analyse des données .....*	*17*

Cette unité d'étude est la troisième d'une série de quatre couvrant le **Domaine II : Sécurité de l'information** et le **Domaine III : Technologie de l'information** du programme d'examen CIA de l'IIA. Ces domaines représentent respectivement 25 % et 20 % de la partie 3 de l'examen CIA et est évalués au niveau cognitif de **base.** Cette unité d'étude couvre également l'analyse des données, dernier sujet du **domaine I : Le sens des affaires** du programme d'examen CIA de l'IIA. Ce domaine représente 35 % de la partie 3 de l'examen CIA, et ce sujet du domaine est testé au niveau cognitif de **base.** Les parties pertinentes du syllabus sont mises en évidence ci-dessous et à la page suivante. (Le programme complet se trouve à l'annexe A.)

7.1 : CADRES DE CONTRÔLE ET CADRE DE L'ORGANISATION INTERNATIONALE DE NORMALISATION (ISO)

L'intégration croissante des contrôles sur les systèmes automatisés avec le système global de contrôle interne de l'organisation est plus clairement démontrée dans les cadres eSAC et COBIT. Ces documents traitent en détail du rôle joué par les systèmes automatisés dans la poursuite de la mission de l'organisation, la protection des biens, etc. Les candidats à l'examen CIA doivent être conscients non seulement des contrôles détaillés comme les vérifications sur place, mais aussi du rôle que joue le contrôle des TI dans la mise en œuvre de la stratégie de l'organisation.

1. **Cadre de contrôle**
   a. Un cadre de contrôle est un modèle pour établir un système de contrôle interne.
      1) Le cadre ne prescrit pas les contrôles proprement dits, mais il incite la direction à se concentrer sur les secteurs à risque et à concevoir les contrôles en conséquence.
      2) Souvent, un cadre de contrôle décrit des "familles" de contrôles, c'est-à-dire des regroupements conceptuels de contrôles qui visent à traiter un type particulier d'exposition au risque.
      3) **ITIL**, un produit d'AXELOS, aide les organisations en se concentrant sur l'allocation des efforts informatiques sur les besoins de l'entreprise et le support des processus de base.
2. **COSO**
   a. *Le* cadre de contrôle le plus connu aux États-Unis est probablement le *contrôle interne - Cadre intégré, publié en 1992 par le Committee of Sponsoring Organizations of the Treadway Commission (COSO). Le cadre est communément appelé «cadre COSO»*.
      1) L'importance et la durabilité du cadre COSO ont été renforcées lorsque la Securities and Exchange Commission des États-Unis l'a reconnu comme un modèle approprié pour la conception de contrôles internes conformément aux exigences de la Sarbanes-Oxley Act of 2002.
   b. Le cadre du COSO définit le contrôle interne comme suit : *Processus, mis en œuvre par le conseil d'administration, la direction et d'autres membres du personnel d'une organisation, conçu pour fournir une assurance raisonnable quant à l'atteinte des objectifs dans les catégories suivantes :*
      - *Efficacité et efficience des opérations*
      - *Fiabilité de l'information financière*
      - *Conformité aux lois et règlements applicables*
   c. Le COSO décrit en outre cinq composantes d'un système de contrôle interne :
      1) Environnement de contrôle
      2) Évaluation des risques
      3) Activités de contrôle

4) Information et communication
5) Surveillance.

3. eSAC

a. *Le* ***Cadre électronique de contrôle et d'audit des systèmes d'information (eSAC)*** est une publication de l'IIA. L'objectif de l'eSAC est de fournir un cadre de contrôle interne pour le commerce électronique. Dans le modèle eSAC, les processus internes de l'organisation acceptent les intrants et produisent des extrants.

1) Entrées : Mission, valeurs, stratégies et objectifs
2) Sorties : Résultats, réputation et apprentissage

b. Les objectifs généraux de contrôle du modèle eSAC sont influencés par ceux du cadre du COSO :

1) Efficacité et efficience opérationnelles
2) Communication de l'information financière et d'autres informations de gestion
3) Conformité aux lois et règlements
4) Sauvegarde des actifs

c. Les objectifs de l'eSAC en matière d'assurance des activités des TI se répartissent en cinq catégories :

1) **Disponibilité.** L'organisation doit s'assurer que l'information, les processus et les services sont disponibles en tout temps.
2) **Capacité.** L'organisation doit s'assurer que les transactions sont effectuées de façon fiable et en temps opportun.
3) **Fonctionnalité.** L'organisation doit s'assurer que les systèmes sont conçus selon les spécifications de l'utilisateur pour répondre aux exigences opérationnelles.
4) **Protection.** L'organisation doit s'assurer qu'une combinaison de contrôles physiques et logiques empêche l'accès non autorisé aux données du système ou leur utilisation.
5) **Responsabilité.** L'organisation doit s'assurer que le traitement des transactions est exact, complet et non réfutable.

4. COBIT 4.1

a. En ce qui concerne plus particulièrement les contrôles informatiques, le cadre le plus connu est le *COBIT (Control Objectives for Information and related Technology)*. La version 4.1 de ce cadre a été publiée en 2007 par l'IT Governance Institute.

1) L'ISACA a publié le COBIT 5 en avril 2012 (décrit au point 5. à partir de la page 5). Le COBIT 5 consolide les principes du COBIT 4.1.

b. Les systèmes d'information automatisés ont été intégrés à toutes les fonctions de l'organisation moderne, faisant de la gouvernance informatique une partie intégrante de la gouvernance organisationnelle globale. Le modèle COBIT pour la gouvernance des TI comporte cinq domaines d'intérêt :

1) Alignement stratégique
2) Livraison de valeur
3) Gestion des ressources
4) Gestion des risques
5) Mesure du rendement

c. Le cadre COBIT présente quatre caractéristiques :

1) Axée sur les affaires
2) Orienté processus
3) Basé sur les contrôles
4) piloté par la mesure

d. Chaque caractéristique comprend plusieurs composants.

1) Caractéristiques axées sur les affaires

a) Cette caractéristique énumère sept critères d'information distincts mais qui se chevauchent : efficacité, efficience, confidentialité, intégrité, disponibilité, conformité et fiabilité.

b) Les objectifs d'affaires doivent alimenter les objectifs des TI, ce qui permet à l'organisation de concevoir l'architecture d'entreprise appropriée pour les TI.

c) Les ressources informatiques comprennent les applications, l'information, l'infrastructure et le personnel.

2) Caractéristiques orientées processus. Cette partie du modèle comporte quatre domaines :

a) Aligner, planifier et organiser
b) Construire, acquérir et mettre en œuvre
c) Fourniture, service et soutien
d) Surveiller, étudier et évaluer

3) Caractéristiques basées sur les contrôles. "Un objectif de contrôle des TI est un énoncé du résultat souhaité ou de l'objectif à atteindre en mettant en œuvre des procédures de contrôle dans une activité particulière des TI. Le "COBIT décrit les contrôles dans trois domaines :

a) **Contrôles de processus**. "La direction opérationnelle utilise des processus pour organiser et gérer les activités informatiques en cours."

b) **Contrôles d'affaires**. Celles-ci affectent la TI à trois niveaux : le niveau de la direction, le niveau des processus opérationnels et le niveau du soutien des TI.

c) **Contrôles généraux informatiques et contrôles d'application**. Cette distinction pour les contrôles informatiques est très ancienne.

i) "Les contrôles généraux sont les contrôles intégrés dans les processus et services informatiques. . . . Les contrôles intégrés dans les applications de processus métier sont communément appelés contrôles applicatifs."

4) Caractéristiques pilotées par la mesure

a) La pièce maîtresse du cadre COBIT dans ce domaine est le **modèle de maturité**.

i) Le modèle de maturité se concentre sur trois dimensions de la maturité : la capacité, la couverture et le contrôle.

ii) "L'organisation doit évaluer dans quelle mesure ses processus informatiques sont bien gérés. L'échelle suggérée utilise les classements inexistant, initial, répétable, défini, géré et optimisé."

iii) Ses avantages sont notamment les suivants :

- Il aide les professionnels à expliquer les lacunes de la gestion des processus informatiques.
- Il est utilisé pour l'évaluation complète, l'analyse des lacunes et la planification de l'amélioration.

b) Mesure du rendement

Les objectifs et les mesures sont définis dans le COBIT à trois niveaux :

- *Des objectifs et des mesures informatiques qui définissent ce que l'entreprise attend de l'informatique*
- *Des buts et des paramètres de processus qui définissent ce que les processus des TI doivent fournir pour soutenir les objectifs des TI.*
- *Mesure de la performance des processus*

5. COBIT 5 -- Un cadre pour la gouvernance et la gestion des TI

a. Comme on l'a déjà mentionné, le COBIT est le cadre de contrôle et de gouvernance le plus connu en matière de technologie de l'information.

1) Dans sa version d'origine, le COBIT se concentrait sur les contrôles de processus informatiques spécifiques.

2) Au fil des ans, la technologie de l'information s'est progressivement répandue dans tous les aspects des activités de l'organisation. La TI ne peut plus être considéré comme une fonction distincte des autres aspects de l'organisation.

a) L'évolution du COBIT a reflété ce changement dans la nature des TI au sein de l'organisation.

b. **Critères d'information**

1) **L'efficacité a** trait à la pertinence de l'information par rapport au processus opérationnel et à sa réception en temps opportun, de façon correcte, uniforme et utilisable.
2) **L'efficience** concerne la fourniture d'informations par l'utilisation optimale (la plus productive et la plus économique) des ressources.
3) **La confidentialité** concerne la protection des informations sensibles contre la divulgation non autorisée.
4) **L'intégrité a** trait à l'exactitude et à l'intégralité de l'information ainsi qu'à sa validité conformément aux valeurs et aux attentes de l'entreprise.
5) **La disponibilité a** trait à la disponibilité de l'information lorsque le processus opérationnel l'exige, maintenant et à l'avenir. Elle concerne également la sauvegarde des ressources nécessaires et des capacités associées.
6) **La conformité a** trait au respect des lois, des règlements et des ententes contractuelles auxquels le processus opérationnel est assujetti, c.-à-d. les critères opérationnels imposés de l'extérieur ainsi que les politiques internes.
7) **La fiabilité a** trait à la fourniture d'une information appropriée à la direction pour lui permettre d'exploiter l'entité et d'exercer ses responsabilités fiduciaires et de gouvernance.

c. **Domaines d'intervention de la gouvernance des TI**

1) **L'alignement stratégique** vise à assurer le lien entre les plans d'affaires et les plans des TI, à définir, à maintenir et à valider la proposition de valeur des TI et à harmoniser les opérations des TI avec les opérations de l'entreprise.
2) **La livraison de valeur** consiste à exécuter la proposition de valeur tout au long du cycle de livraison, à s'assurer que l'informatique fournit les avantages promis par rapport à la stratégie, à se concentrer sur l'optimisation des coûts et à prouver la valeur intrinsèque de l'informatique.
3) **La gestion des ressources** concerne l'investissement optimal et la bonne gestion des ressources informatiques critiques.
4) **Le risque lié à la TI** est le risque commercial associé à l'utilisation, à la propriété, à l'exploitation, à la participation, à l'influence et à l'adaptation des TI dans une entreprise ou une organisation.
5) **La gestion des risques** comprend la sensibilisation aux risques par les cadres supérieurs, la compréhension des exigences de conformité, la transparence au sujet des risques importants pour l'entreprise et l'intégration des responsabilités en matière de gestion des risques dans l'organisation.
6) **La mesure du rendement permet** de suivre et de surveiller la mise en œuvre de la stratégie, l'achèvement du projet, l'utilisation des ressources, le rendement des processus et la prestation des services.

d. Le COBIT définit les activités informatiques dans un modèle de processus générique au sein de quatre processus :

1) **Aligner, planifier et organiser.** Fournit une orientation pour la prestation de solutions et la prestation de services.
2) **Construire, acquérir et mettre en œuvre.** Les solutions doivent être identifiées, développées ou acquises et intégrées dans le processus opérationnel.
3) **Fourniture, service et soutien.** Fournit des instructions pour la gestion de la sécurité et de la continuité, le soutien des services aux utilisateurs et la gestion des données et des installations opérationnelles.
4) **Surveiller, étudier et évaluer.** Les processus doivent être régulièrement évalués au fil du temps pour s'assurer de leur qualité et de leur conformité aux exigences de contrôle.

e. **Ressources informatiques**

1) **Les applications** sont les systèmes d'utilisateur automatisés et les procédures manuelles qui traitent l'information.
2) **L'information** est les données, sous toutes leurs formes, entrées, traitées et sorties par les systèmes d'information sous n'importe quelle forme utilisée par l'entreprise.
3) **L'infrastructure** est la technologie et les installations qui permettent le traitement des demandes.
4) **Les personnes** sont le personnel nécessaire pour planifier, organiser, acquérir, mettre en œuvre, livrer, soutenir, surveiller et évaluer les systèmes d'information.

f. **Cinq principes clés**

1) **Principe 1 : Répondre aux besoins des parties prenantes.**
   a) Le COBIT 5 affirme que la création de valeur est le besoin le plus fondamental des parties prenantes. Ainsi, la création de valeur pour les parties prenantes est l'objectif fondamental de toute entreprise, commerciale ou non.
      i) Dans ce modèle, la création de valeur est obtenue en équilibrant trois composantes :
         - Réalisation des bénéfices
         - Optimisation (et non minimisation) du risque
         - Utilisation optimale des ressources
   b) Le COBIT 5 reconnaît également que les besoins des parties prenantes ne sont pas satisfaits. Ils évoluent sous l'influence de facteurs internes (p. ex. changements dans la culture organisationnelle) et de facteurs externes (p. ex. les technologies perturbatrices).
      i) Ces facteurs sont collectivement appelés les moteurs des parties prenantes.
   c) En réponse aux besoins identifiés des parties prenantes, des objectifs d'entreprise sont établis.
      i) Le COBIT 5 fournit 17 objectifs d'entreprise génériques qui sont directement liés au modèle de tableau de bord prospectif.
      ii) Ensuite, les objectifs liés aux technologies de l'information sont définis en fonction des objectifs de l'entreprise.
      iii) Enfin, les catalyseurs qui appuient la poursuite des objectifs liés aux TI sont identifiés. Un catalyseur est défini au sens large comme tout ce qui aide à atteindre les objectifs.
      iv) Le COBIT 5 désigne le processus décrit ci-dessus comme la cascade de buts.
2) **Principe 2 : Couvrir l'entreprise de bout en bout**
   a) Le COBIT 5 offre une vue d'ensemble de toutes les fonctions et processus de l'entreprise. Les technologies de l'information sont omniprésentes ; elles ne peuvent être considérées comme une fonction distincte des autres activités de l'entreprise.
      i) Ainsi, la gouvernance informatique doit être intégrée à la gouvernance d'entreprise.
   b) Les TI doivent être considérées à l'échelle de l'entreprise et de bout en bout, c'est-à-dire toutes les fonctions et tous les processus qui régissent et gèrent l'information " où que cette information puisse être traitée ".
3) **Principe 3 : Appliquer un référentiel unique et intégré.**
   a) Reconnaissant la disponibilité de multiples normes et pratiques exemplaires en matière des TI, le COBIT 5 fournit un cadre général pour les TI d'entreprise dans lequel d'autres normes peuvent être appliquées de façon uniforme.
   b) Le COBIT 5 a été conçu comme un cadre général qui ne traite pas de questions techniques particulières, c'est-à-dire que ses principes peuvent être appliqués quel que soit le matériel et les logiciels utilisés.
4) **Principe 4 : Faciliter une approche globale**
   a) Le COBIT 5 décrit sept catégories de catalyseurs qui soutiennent une gouvernance et une gestion complètes des TI :
      i) Principes, politiques et référentiels
      ii) Processus

iii) Structures organisationnelles
iv) Culture, éthique et comportement
v) Information
vi) Services, infrastructure et applications
vii) Personnes, aptitudes et compétences

b) Les trois derniers catalyseurs sont également classés comme des ressources dont l'utilisation doit être optimisée.

c) Les catalyseurs sont interconnectés parce qu'ils

i) Ont besoin de l'apport d'autres catalyseurs pour être pleinement efficace et
ii) Produisent des extrants au profit d'autres catalyseurs.

5) **Principe 5 : Distinguer la gouvernance de la gestion.**

a) La complexité de l'entreprise moderne exige que la gouvernance et la gestion soient traitées comme des activités distinctes.

i) En général, la gouvernance est l'établissement d'objectifs globaux et le suivi des progrès accomplis dans la réalisation de ces objectifs. Le COBIT 5 associe la gouvernance au conseil d'administration.

- Dans tout processus de gouvernance, trois pratiques doivent être abordées : évaluer, diriger et surveiller.

ii) La gestion est l'exécution d'activités dans la poursuite des objectifs de l'entreprise. Le COBIT 5 associe ces activités au management exécutif sous la direction du CEO.

- Dans tout processus de gestion, quatre domaines de responsabilité doivent être abordés : planifier, construire, exécuter et surveiller.

Contexte général

Outre le cadre lui-même, la famille de produits COBIT comprend trois autres documents qui peuvent être achetés séparément : des guides de facilitation, qui décrivent les processus habilitants (c'est-à-dire tout ce qui peut aider à atteindre les objectifs de l'entreprise) ; des guides professionnels, qui fournissent des conseils pour la mise en œuvre du COBIT, ainsi que pour des sujets spécifiques comme la sécurité, la fiabilité et le risque des informations ; et un environnement en ligne permettant une participation et une collaboration simultanées des parties intéressées.

6. Guides pour l'audit des technologies d'information (GTAG, « Global Technology Audit Guide »)

a. Le GTAG de l'IIA sur les risques et les contrôles liés aux technologies de l'information reconnaît trois "familles" de contrôles :

1) Contrôles généraux et d'application, décrits dans la sous-unité 7.3.
2) Contrôles préventifs, détectifs et correctifs

a) Contrôles préventifs " prévenir les erreurs, les omissions ou les incidents de sécurité ".

b) Les contrôles de détection "détectent les erreurs ou les incidents qui échappent aux contrôles préventifs".

c) Contrôles correctifs " corriger les erreurs, les omissions ou les incidents une fois qu'ils ont été détectés ".

3) Contrôles de Gouvernance, de gestion et techniques

a) "Les contrôles de gouvernance ... sont liés aux concepts de gouvernance d'entreprise, qui sont déterminés à la fois par les objectifs et les stratégies de l'organisation et par des organismes externes tels que les organismes de réglementation.

b) Les contrôles de gestion " sont déployés à la suite d'actions délibérées de la direction pour reconnaître les risques pour l'organisation, ses processus et ses actifs ; et adopter des mécanismes et des processus pour atténuer et gérer les risques ".

c) Les contrôles techniques " sont spécifiques aux technologies utilisées au sein des infrastructures informatiques de l'organisation ".

b. Le même GTAG recommande également que chaque organisation utilise les composantes applicables des cadres existants pour catégoriser et évaluer les contrôles des TI et pour fournir et documenter son propre cadre de travail pour la

1) Conformité avec la réglementation et la législation en vigueur,
2) Cohérence avec les objectifs de l'organisation, et

3) Preuves fiables (assurance raisonnable) que les activités sont conformes aux politiques de gouvernance de la direction et qu'elles sont conformes au goût du risque de l'organisation.

7. L'Organisation internationale de normalisation (ISO)

a. En 1987, l'ISO a introduit **ISO 9000**, un groupe de 11 normes volontaires et rapports techniques qui fournissent des conseils pour l'établissement et le maintien d'un **système de management de la qualité (SMQ)**.

1) Les règles de l'ISO précisent que ses normes doivent être révisées tous les cinq ans pour tenir compte de l'évolution des techniques et du marché. (NOTE : ISO n'est pas un acronyme. Cela signifie égal, suggérant que les entités certifiées selon ISO 9000 ont la même qualité.)

b. Les normes visent à assurer la qualité du processus et non du produit. Le marché détermine si un produit est bon ou mauvais.

1) Pour cette raison, l'ISO juge inacceptable que des phrases faisant référence à la certification ISO apparaissent sur des produits ou emballages individuels.

c. ISO 9001:2008 est une norme générique qui énonce les exigences relatives à un SMQ. Elle s'applique lorsqu'une entité doit démontrer sa capacité à (1) vendre un produit qui répond aux exigences du client et aux exigences réglementaires et (2) accroître la satisfaction du client en améliorant le SMQ et en assurant la conformité aux exigences.

d. ISO 9000:2015 développe les concepts énoncés dans ISO 9001:2008 et les rend plus accessibles à tous les types d'entreprises.

8. Aspects de la certification ISO

a. Certaines entités obtiennent la certification ISO parce qu'elles craignent que l'Union européenne n'exige le respect de ces normes pour tenter de restreindre les importations.

1) Les normes ne sont pas encore obligatoires. Toutefois, Elles sont exigées pour certains produits réglementés (pour lesquels la santé et la sécurité sont des préoccupations), comme les instruments médicaux, l'équipement de télécommunications et les appareils à gaz.

2) Certains clients exigent que les fournisseurs s'inscrivent.

3) L'enregistrement ISO 9000 peut être nécessaire pour être compétitif. Il rend les clients plus à l'aise avec les produits et services des fournisseurs.

4) De nombreuses entités qui mettent en œuvre les normes apportent ainsi des améliorations aux processus internes et à la qualité. ISO 9000 les oblige à partager l'information et à comprendre qui sont les clients et utilisateurs internes.

b. Un registraire ou un auditeur externe doit être choisi. Les registraires sont habituellement des spécialistes de certains codes de la Classification type des industries (CTI). La certification par un bureau d'enregistrement évite à chaque client d'avoir à auditer un fournisseur.

1) Après une visite sur place, le registraire, s'il est convaincu qu'un système qualité est conforme à la norme choisie, délivre un certificat décrivant la portée de l'enregistrement. L'enregistrement est généralement accordé pour une période de 3 ans.

2) Tous les employés font l'objet d'une vérification. Ils doivent être capables d'expliquer ce qu'ils font et de démontrer qu'ils font ce qu'ils disent.

9. Exigences de base d'un SMQ ISO

a. **Identification des processus clés**

1) Les processus clés affectant la qualité doivent être identifiés et inclus.

2) Une approche de gestion des processus doit être utilisée. Elle gère l'entité comme un ensemble de processus liés qui sont contrôlés en vue d'une amélioration continue.

b. **Exigences générales**

1) L'entité doit avoir une politique et des objectifs de qualité. Elle doit également concevoir un SMQ pour contrôler le rendement du processus. Les objectifs de qualité sont mesurables et spécifiques.

2) Le SMQ est documenté dans
   a) la politique qualité,
   b) le manuel de la qualité,
   c) les procédures,
   d) les instructions de travail et
   e) les dossiers.
3) L'entité doit également démontrer sa capacité à accroître la satisfaction des clients en améliorant le SMQ et en assurant la conformité aux exigences.

c. **Responsabilité de la direction**

1) La direction
   a) examine la politique de qualité,
   b) analyse les données sur le rendement du SMQ et
   c) évalue les possibilités d'amélioration et le besoin de changement.
2) La direction s'assure que des systèmes existent pour déterminer et satisfaire les besoins des clients.

d. **Gestion des ressources**

1) Les ressources nécessaires pour améliorer le SMQ et satisfaire les besoins des clients doivent être fournis.

e. **Réalisation du produit**

1) Ces processus se traduisent par des produits ou des services reçus par les clients. Ils doivent être planifiés et contrôlés.
2) Il s'agit :
   a) des moyens de contrôle,
   b) des objectifs,
   c) de la documentation et des dossiers nécessaires et
   d) des critères d'acceptation.

f. **Mesure, analyse et amélioration**

1) L'entité doit avoir des processus pour (a) l'inspection, (b) les tests, (c) la mesure, (d) l'analyse et (e) l'amélioration.

10. Autres domaines de normalisation

a. L'ISO a également publié ISO 14000, un ensemble de normes environnementales. Ces normes ont un objectif comparable à celui de la norme ISO 9000, mais elles s'appliquent aux systèmes de qualité environnementale.

1) Bien qu'elles n'aient pas été adoptées aussi largement que les normes ISO 9000, elles peuvent devenir nécessaires pour la conduite des affaires internationales. Certains pays européens ont déjà mis en place des normes de systèmes environnementaux, et la relation entre ces normes nationales et ISO 14000 n'est pas claire. Toutefois, les normes des différents pays sont généralement plus strictes.

b. La portée d'ISO 19011:2002 s'étend (1) aux principes de l'audit, (2) à la gestion des programmes d'audit, (3) à la réalisation d'audits de SMQ et de systèmes de management environnemental (SME), et (4) à la compétence des auditeurs SMQ et SME.

1) Elle s'applique à toutes les entités qui doivent effectuer des vérifications internes ou externes des SMQ ou des systèmes de management environnemental ou gérer un programme de vérification.
2) La norme ISO 19011 peut s'appliquer à d'autres types d'audits si l'on tient dûment compte de l'identification des compétences requises des auditeurs.

c. ISO 10012:2003 est une norme générique. Elle traite de la gestion des processus de mesure et de la confirmation de l'équipement de mesure utilisé pour appuyer la conformité aux mesures requises.

1) Elle énonce les exigences de gestion de la qualité d'un **système de gestion des mesures (SGM)** qui peut être utilisé dans le cadre du système de gestion global.
2) Elle ne doit pas être utilisée comme une exigence pour démontrer la conformité à d'autres normes. Les parties intéressées peuvent convenir d'utiliser la norme ISO 10012:2003 comme intrant pour satisfaire aux exigences des SGM dans les activités de certification.
    a) D'autres normes s'appliquent à des éléments spécifiques affectant les résultats de mesure, p. ex. détails sur les méthodes de mesure, la compétence du personnel ou les comparaisons entre laboratoires.

d. La norme ISO 14063:2006 énonce les principes, les politiques, les stratégies et les activités de communication environnementale, qu'elle soit externe ou interne. Elle tient compte des circonstances particulières des communications environnementales et s'applique à chaque entité, qu'elle ait ou non un SME.

e. Le Guide ISO 64:2008 s'applique aux questions environnementales dans l'établissement des normes de produits. Son but est d'aider les normalisateurs à minimiser les effets négatifs sur l'environnement à chaque étape du cycle de vie d'un produit.

f. ISO 14050:2009 est un glossaire du vocabulaire du management environnemental.

g. **Note de l'auteur** : *Il n'est pas nécessaire d'enregistrer les numéros ISO en mémoire. Le simple fait d'avoir une compréhension générale de ces concepts et de leurs implications sera suffisant pour vous aider à réussir l'examen*.

h. La famille de normes ISO/CEI 27000 sur les systèmes de management de la sécurité de l'information (ISMS) (également appelée série ISO 27000) est publiée par l'ISO et la Commission électrotechnique internationale (CEI).

1) ISO 27000 a été créée pour fournir des normes ISMS mondialement reconnues pour les organisations de toutes les industries, quelle que soit leur taille.
2) Au fur et à mesure que la technologie évolue, de nouvelles normes du SMSI sont élaborées afin de répondre aux besoins en matière de sécurité.
    a) ISO 27000 contient une vue d'ensemble et du vocabulaire.
    b) La norme ISO 27001 contient des exigences.
    c) Toutes les autres normes ISO 27000 contiennent des lignes directrices sur les meilleures pratiques.

i. La norme ISO / IEC 38500:2015, « Technologies de l'information – Gouvernance de l'informatique pour l'organisation », est un cadre de norme internationale qui fournit à la direction générale, aux conseils d'administration et aux autres propriétaires un ensemble de principes directeurs pour s'assurer que les systèmes informatiques sont acceptables, efficaces et efficients dans l'organisation. Elle vise spécifiquement les processus et les décisions de gestion concernant les systèmes d'information et ce indépendamment du fait que les processus sont considérés comme des activités internes ou qu'ils soient sous-traités.

j. La norme ISO / CEI 38500 fournit également des conseils pour les membres de la direction ; les contrôleurs et les autres gestionnaires de ressources; les experts juridiques et comptables entre autres ; le matériel, les logiciels et les fournisseurs de services de communications; les consultants et autres fournisseurs de services internes ou externes; et les auditeurs spécialisés dans l'informatique. Ce guide est conçu pour aider ces professionnels à fournir des conseils et une perspective adéquats.

7.2 : ASPECTS DU TRAITEMENT AUTOMATISÉ DE L'INFORMATION

1. Caractéristiques du traitement automatisé

a. L'utilisation d'ordinateurs dans les systèmes d'information de l'entreprise a des effets fondamentaux sur la nature des transactions commerciales, les procédures suivies, les risques encourus et les méthodes d'atténuation de ces risques. Ces effets découlent des caractéristiques qui distinguent le traitement informatisé du traitement manuel.

b. **Piste des transactions**

1) Une piste complète utile à l'audit et à d'autres fins pourrait n'exister que pour une courte période ou seulement sous une forme lisible par ordinateur. La nature de la piste dépend souvent du mode de traitement des transactions, par exemple, si les transactions sont mises en lots avant le traitement ou si elles sont traitées immédiatement lorsqu'elles surviennent.

c. **Traitement uniforme des transactions**

1) Le traitement informatique soumet uniformément des opérations semblables aux mêmes instructions de traitement et élimine ainsi pratiquement toute erreur d'écriture, mais les erreurs de programmation (ou d'autres erreurs systématiques semblables dans le matériel ou le logiciel) entraîneront le traitement incorrect de toutes les opérations semblables lorsqu'elles sont traitées dans les mêmes conditions.

d. **Séparation des fonctions**

1) De nombreux contrôles autrefois effectués par des personnes distinctes peuvent être concentrés dans des systèmes informatiques. Par conséquent, une personne qui a accès à l'ordinateur peut exécuter des fonctions incompatibles. En conséquence, d'autres contrôles peuvent être nécessaires pour atteindre les objectifs de contrôle habituellement atteints par la séparation des fonctions.

e. **Possibilité d'erreurs et de fraude**

1) Le risque que des personnes, y compris celles qui effectuent des procédures de contrôle, aient un accès non autorisé aux données, modifient des données sans preuve visible ou aient accès (directement ou indirectement) à des biens peut être plus grand dans les systèmes informatiques. Une diminution de la participation humaine dans le traitement des transactions peut réduire le risque d'erreurs et de fraudes. Les erreurs ou les fraudes dans la conception ou le changement des programmes d'application peuvent rester longtemps inaperçues.

f. **Possibilité d'une supervision accrue de la gestion**

1) Les systèmes informatiques offrent à la direction de nombreux outils d'analyse pour l'examen et la supervision des opérations. Ces contrôles supplémentaires peuvent améliorer le contrôle interne. Par exemple, les comparaisons traditionnelles des ratios d'exploitation réels et budgétés et les rapprochements de comptes sont souvent disponibles pour examen plus rapidement. De plus, certaines applications programmées fournissent des statistiques sur les opérations informatiques qui peuvent être utilisées pour surveiller le traitement réel.

g. **Initiation ou exécution ultérieure de transactions par ordinateur**

1) Certaines opérations peuvent être initiées automatiquement ou certaines procédures nécessaires à l'exécution d'une opération peuvent être exécutées automatiquement par un système informatique. L'autorisation de ces transactions ou procédures peut ne pas être documentée de la même manière que dans un système manuel, et l'autorisation de la direction peut être implicite dans son acceptation de la conception du système.

h. **Dépendance des contrôles dans d'autres domaines à l'égard des contrôles sur le traitement informatique**

1) Le traitement informatique peut produire des rapports et d'autres résultats qui sont utilisés dans l'exécution des procédures de contrôle manuel. L'efficacité de ces contrôles peut dépendre de l'efficacité des contrôles sur l'intégralité et l'exactitude du traitement informatique. Par exemple, l'efficacité d'un examen manuel d'une liste d'exceptions produite par ordinateur dépend des contrôles sur la production de la liste.

2. Deux modes de traitement de base

a. **Traitement par lots**

1) Dans ce mode, les transactions sont accumulées et soumises à l'ordinateur en un seul lot. Dans les premiers temps de l'informatique, c'était la seule façon de traiter un travail.

Dans le traitement par lots, l'utilisateur ne peut pas influencer le processus une fois le travail commencé (sauf pour demander qu'il soit interrompu complètement). Il doit attendre jusqu'à ce que le travail soit terminé pour voir si des transactions dans le lot ont été rejetées et n'ont pas été affichées.

2) Malgré les énormes progrès de la technologie informatique, cette accumulation de transactions à traiter en différé est encore largement utilisée. Il est très efficace pour des applications telles que la paie, car un grand nombre d'opérations de routine doivent être traitées selon un calendrier régulier.

3) La **comptabilisation de notes** est utilisée par les banques pour des transactions financières et autres pour créer des entrées en temps réel qui sont envoyées vers un fichier mémo temporaire. Le fichier mémo permet la consultation des informations mises à jour. À une heure prévue, le fichier mémo est traité par lots afin de mettre à jour le fichier maître. De cette manière, les données sont disponibles immédiatement à des fins de consultation, mais les contrôles de traitement par lots sont appliqués avant que les changements ne deviennent permanents.

a) La comptabilisation de notes est une étape intermédiaire entre le traitement par lots et le traitement en temps réel.

b. **En ligne, traitement en temps réel**

1) Dans certains systèmes, il est essentiel de disposer à tout moment des informations les plus récentes pour assurer le bon fonctionnement du système. Un système de réservation de billets d'avion en est un exemple courant.

2) Dans un système en ligne et en temps réel, la base de données est mise à jour dès la saisie de la transaction par l'opérateur. Ces systèmes sont appelés systèmes de **traitement transactionnel en ligne (OLTP).**

7.3 : CONTRÔLE INFORMATIQUE

1. Classification des contrôles

a. *Le* COBIT, connu sous le nom de ***Control Objectives for Information and related Technology*** a été largement acceptés. Il fournit un modèle de l'impact des contrôles internes d'une organisation sur les TI :

*Au **niveau de la direction générale**, les objectifs opérationnels sont fixés, des politiques sont établies et des décisions sont prises sur la façon de déployer et de gérer les ressources de l'entreprise pour exécuter la stratégie d'entreprise.*

*Au **niveau des processus d'affaires, des** contrôles sont appliqués à des activités commerciales particulières. La plupart des processus opérationnels sont automatisés et intégrés aux systèmes d'applications informatiques, de sorte que bon nombre des contrôles à ce niveau sont également automatisés. Ces contrôles sont connus sous le nom de contrôles d'application.*

*Pour **soutenir les processus opérationnels**, l'informatique fournit des services informatiques, généralement sous la forme d'un service partagé à de nombreux processus opérationnels, car de nombreux processus informatiques de développement et d'exploitation sont fournis à l'ensemble de l'entreprise et une grande partie de l'infrastructure informatique est fournie sous forme de service commun (par exemple, réseaux, bases de données, systèmes d'exploitation et stockage). Les contrôles appliqués à toutes les activités de services informatiques sont appelés contrôles généraux informatiques.*

b. L'organisation doit mettre en place des contrôles appropriés à chacun des trois niveaux décrits dans le modèle COBIT.

1) Par exemple, au niveau de la direction, un comité directeur des TI devrait être mis sur pied, composé de cadres supérieurs de la fonction TI et des fonctions des utilisateurs finaux. Le comité approuve les projets de développement, affecte les ressources et examine leur avancement.

2) Le comité directeur veille également à ce que les demandes de nouveaux systèmes soient harmonisées avec le plan stratégique global de l'organisation.

c. L'interaction entre les contrôles généraux et les contrôles d'application est cruciale pour un audit.

Selon le COBIT, *Le fonctionnement fiable de ces contrôles généraux est nécessaire pour que l'on puisse se fier aux contrôles d'application.*

1) Étant donné que les contrôles généraux ont une incidence sur l'ensemble de l'environnement de traitement de l'organisation, l'auditeur doit s'assurer de leur bon fonctionnement avant de se fier aux contrôles des applications.

d. Voici les catégories de **contrôles généraux** : développement de systèmes, gestion du changement, sécurité et opérations informatiques.

1) Les contrôles généraux informatiques sont mesurés par le nombre d'éléments suivants

a) Incidents qui nuisent à la réputation publique,
b) les systèmes qui ne répondent pas aux critères de sécurité ; et
c) Violations de la séparation des tâches.

e. Voici des exemples de types de **contrôles d'application** : intégralité, exactitude, validité, autorisation et séparation des tâches.

1) Cette classification reflète le fait qu'une application informatique est l'automatisation d'un processus d'affaires et a les mêmes objectifs de contrôle.

2. **Les contrôles généraux** sont le cadre dans lequel la fonction informatique fonctionne. Elles affectent l'ensemble de l'environnement de traitement de l'organisation et comprennent généralement les contrôles sur : a) l'exploitation des centres de données et des réseaux ; b) l'acquisition, la modification et la maintenance des logiciels des systèmes ; c) la sécurité des accès ; et d) l'acquisition, le développement et la maintenance des systèmes d'application.

3. **Les Contrôles de l'administration informatique sur les opérations**

a. Une organisation moderne devrait reconnaître la technologie de l'information comme une fonction distincte dotée de ses propres compétences techniques et de gestion. Une organisation qui permet à chaque secteur fonctionnel d'acquérir et d'administrer ses propres systèmes de façon isolée n'est pas sérieuse au sujet d'un contrôle adéquat.

b. Traiter la TI comme un secteur fonctionnel distinct de l'organisation implique la désignation d'un directeur des systèmes d'information (DSI) ou d'un directeur technique et l'établissement d'un comité directeur des systèmes d'information pour établir une orientation cohérente pour les systèmes de l'organisation et établir des priorités pour les projets de technologie de l'information.

4. **La séparation des tâches** est vitale parce qu'une séparation des fonctions (autorisation, enregistrement et accès aux actifs) peut ne pas être possible dans un environnement informatique. Par exemple, un ordinateur peut imprimer des chèques, enregistrer des décaissements et générer des informations pour rapprocher le solde du compte. Ces activités sont habituellement séparées dans un système manuel. La répartition des tâches au sein de la fonction TI est abordée dans la sous-unité 1 de l'unité d'étude 6.

5. Les contrôles de l'acquisition, du changement et de la maintenance des logiciels sont les suivants

a. **Contrôles des logiciels systèmes,** qui garantissent que les systèmes d'exploitation, les utilitaires et les systèmes de gestion des bases de données ne sont acquis et modifiés que sous étroite supervision et que les mises à jour des fournisseurs sont régulièrement installées.

b. **Les contrôles des logiciels d'application,** qui permettent de s'assurer que les programmes utilisés pour le traitement des opérations (p. ex. la paie et les comptes débiteurs) sont rentables et stables.

6. **Contrôles matériels.** Les contrôles matériels sont des contrôles intégrés, conçus pour détecter et signaler des erreurs ou des défaillances matérielles. Le matériel devient plus fiable, mais il peut toujours être une source possible d'erreurs. Après avoir déterminé l'existence de contrôles matériels, les auditeurs doivent s'efforcer à rechercher la manière dont l'organisation réagit à des erreurs matérielles au lieu de vérifier les contrôles eux-mêmes. Les contrôles signalent la présence du problème mais ne résolvent pas les erreurs de sortie en résultant. Un processus doit donc être en place. Voici quelques types de contrôles matériels :

a. **Contrôle par caractère redondant.** Tous les éléments de données transmis reçoivent un bit supplémentaire (caractère) de données mathématiquement lié aux données. Les changements anormaux annulent la relation mathématique.

b. **Contrôle de l'équipement**. Il s'agit de contrôles des circuits qui détectent des erreurs matérielles.

c. **Vérification par duplication.** Un processus est exécuté deux fois et comparé.

d. **Contrôle par écho.** Les données reçues sont renvoyées à l'expéditeur à des fins de comparaison.

e. **Composants à tolérance de pannes.** Les composants à tolérance de pannes ont des redondances matérielles ou logicielles pour permettre la poursuite des opérations si un système tombe en panne.

7. Contrôles d'application

a. Selon les GTAG de l'IIA, les contrôles d'application sont ceux qui ont trait à la portée des processus opérationnels ou des systèmes d'application individuels. L'objectif des contrôles de l'application est de s'assurer que

1) Les données d'entrée sont exactes, complètes, autorisées et correctes.
2) Les données sont traitées comme prévu dans un délai acceptable.
3) Les données stockées sont exactes et complètes.
4) Les extrants sont précis et complets.
5) Un registre est tenu à jour pour suivre le processus de traitement des données, de l'entrée au stockage et à la sortie finale.

b. Lors de la conception des contrôles d'entrée des données, il faut accorder la priorité à l'autorisation, à la validation et à la notification des erreurs.

c. Le point le plus économique pour corriger les erreurs de saisie dans une application est le moment où les données sont saisies dans le système.

1) Pour cette raison, les contrôles d'entrée sont au cœur de l'évaluation des contrôles d'application par l'auditeur interne. Chacun des deux principaux types de modes de traitement a ses propres commandes.

d. Contrôles sur les entrées

1) Les contrôles sur les entrées sont destinés à empêcher les erreurs informatiques en contrôlant les données lors de leur saisie manuelle ou électronique dans le système. Les erreurs de saisie sont les sources les plus fréquentes d'erreur et les auditeurs internes doivent mettre l'accent sur les tests de ces contrôles. Les faux en entrée/faux en sortie (GIGO, « garbage-in, garbage-out ») désignent le fait que quelle que soit la qualité de traitement et de sortie, si les entrées sont erronées, les sorties le seront également. Les contrôles sur les saisies manuelles incluent l'exigence d'autorisations avant la saisie et après une vérification, l'utilisation de formulaires prénumérotés concis et la formation du personnel de saisie des données.

2) Les aides électroniques pour les entrées manuelles incluent les formats d'écran faciles d'utilisation qui demandent aux utilisateurs des informations requises et l'utilisation de champs obligatoires. Une vérification de champ consiste à vérifier si les informations d'un champ de saisie sont exhaustives. Les menus déroulants et les fonctions similaires ne permettent que des entrées prédéfinies spécifiques. Pour protéger les informations sensibles, la vérification des frappes requiert que les données soient saisies deux fois, par différentes personnes si possible, et met en évidence les différences. Les étiquettes de fichiers et les conventions d'étiquetage identifient les enregistrements ou transactions corrects.

3) Les contrôles par lots accumulent les transactions, puis appliquent des tests au lot, par exemple, un total de contrôle. Le total de contrôle est rapproché au niveau de différents points de transfert. Les systèmes en temps réel ne peuvent pas utiliser les contrôles par lots et doivent se baser sur une vérification visuelle. Par exemple, une fois qu'un numéro de fournisseur est saisi, le système peut afficher le nom du fournisseur et demander une vérification.

4) Les contrôles de correction d'erreurs de saisie sont problématiques car une erreur existe déjà et la correction pourrait provoquer des erreurs supplémentaires. Les auditeurs internes doivent attentivement vérifier les rapports d'erreur avant de décider quoi faire. Une fois la décision prise, les fichiers sont mis à jour avec les nouvelles entrées et les soldes sont ajustés.

e. **Contrôles d'entrée par lots**

1) **Les totaux financiers** résument les montants monétaires dans un champ d'information d'un groupe d'enregistrements. Le total produit par le système après le traitement du lot est comparé au total produit manuellement au préalable.

2) **Le nombre d'enregistrements** suit le nombre d'enregistrements traités par le système à des fins de comparaison avec le nombre d'enregistrements que l'utilisateur s'attendait à voir traités.

3) **Les totaux de hachage** sont des totaux de contrôle sans signification définie, tels que le total des numéros de fournisseur ou des numéros de facture, qui sont utilisés pour vérifier l'intégralité des données.

4) **Version de gestion**. Un lot n'est pas validé pour traitement tant qu'un responsable n'a pas été revu et approuvé.

EXEMPLE

Une entreprise a les factures suivantes dans un lot:

N° de facture	Produit	Quantité	PU
303	G7	100	15 $ US
305	A48	200	5
353	L30	125	10
359	Z26	150	20

Le total de hachage est un total de contrôle sans signification définie, tel que le total des numéros d'employé ou le total des factures, utilisé pour vérifier l'exhaustivité des données. En utilisant les numéros de facture, le total de hachage serait de 1320.

f. **Contrôles d'entrée en ligne ou en temps réel**

1) Le **pré-formatage** des écrans de saisie de données, c'est-à-dire leur imitation de la mise en page d'un formulaire imprimé, peut aider l'opérateur à saisir les bons champs.

2) Les **contrôles de format**. Il s'agit de vérifications pour déterminer si les données sont saisies dans un format acceptable, par exemple, une date est saisie au format mm/jj/aaaa et non au format mm/jj/aa (ou en Europe, jj/mm/aaaa).

3) Les **contrôles d'édition**. Il s'agit de tests automatisés appliqués aux champs de données. Certains de ces contrôles peuvent également être considérés comme des contrôles de traitement.

4) **Les contrôles de validité** comparent les données saisies dans une zone donnée avec une table des valeurs valables pour cette zone. Par exemple, le numéro de fournisseur d'une demande de réduction de chèque doit correspondre à la table des fournisseurs actuels et le numéro de facture doit correspondre à la table de facture approuvée.

5) **Les contrôles de limites (raison) et de Plages de test** sont basés sur les limites connues de l'information donnée. Par exemple, le nombre d'heures travaillées par semaine doit se situer entre 0 et 100, et tout ce qui dépasse cette fourchette doit être autorisé par la direction.

6) **Chiffres de contrôle.** Un chiffre supplémentaire est ajouté. Il est lié par un algorithme aux chiffres restants et permet de déterminer si le nombre a été saisi de manière incorrecte par transposition. Il est utilisé pour les cartes de crédit.

7) **Les contrôles de séquence** sont basés sur la logique selon laquelle l'efficacité du traitement est considérablement accrue lorsque les fichiers sont triés sur un champ désigné, appelé "clé", avant des opérations telles que la comparaison. Si le système découvre qu'un document n'est pas en ordre, il peut indiquer que les dossiers n'ont pas été correctement préparés pour le traitement.

8) **Les contrôles de solde nul** rejetteront toute transaction ou tout lot de transactions dans lequel la somme de tous les débits et crédits n'est pas égale à zéro.

9) **La vérification en boucle fermée** se produit lorsque les entrées d'un utilisateur sont transmises à l'ordinateur, traitées et affichées en retour à l'utilisateur pour vérification.

g. **Les contrôles du traitement** fournissent une assurance raisonnable que (1) toutes les données soumises pour traitement sont traitées et (2) seules les données approuvées sont traitées. Ces

contrôles sont intégrés au code de l'application par les programmeurs pendant le processus de développement des systèmes.

1) Certains contrôles de traitement répètent les étapes exécutées par les **contrôles d'entrée**, telles que les contrôles de limites et les contrôles par lots.
2) **Les contrôles simultanés** gèrent les situations où deux utilisateurs ou plus tentent d'accéder ou de mettre à jour un fichier ou une base de données simultanément. Ces contrôles garantissent que les résultats corrects sont générés tout en obtenant ces résultats le plus rapidement possibles.
3) **Validation.** Les identificateurs sont comparés aux fichiers maîtres pour déterminer l'existence. Par exemple, toute opération de comptes fournisseurs pour laquelle le numéro fournisseur ne correspond pas à un numéro figurant dans le fichier de base fournisseur est rejetée.
4) **Complétude.** Tout enregistrement pour lequel il manque des données est rejeté.
5) **Contrôles arithmétiques.** Le contrôle croisé compare un montant avec la somme de ses composantes. La vérification du solde nul ajoute les débits et les crédits d'une transaction ou d'un lot pour s'assurer que leur total est nul.
6) **Contrôle de séquence.** L'effort informatique est le plus efficace lorsque les données sont traitées dans un ordre logique, par exemple par numéro de client. Cette vérification permet de s'assurer que le lot est trié dans l'ordre approprié avant le début du traitement.
7) **Totaux de contrôle d'exécution à exécution.** Les contrôles associés à un lot donné sont vérifiés après chaque étape du traitement pour s'assurer que toutes les transactions ont été traitées.
8) **Contrôle d'intégrité de clé.** La clé d'un enregistrement est le groupe de valeurs dans des zones désignées qui identifient de façon unique l'enregistrement. Aucun processus de demande ne devrait pouvoir modifier les données de ces champs clés.

h. **Les contrôles de sortie** fournissent l'assurance que le résultat du traitement (comme les listes ou les affichages de comptes, les rapports, les fichiers, les factures ou les chèques de déboursement) est exact et que seul le personnel autorisé reçoit le résultat.

i. Les contrôles sur les sorties sont des contrôles de détection qui détectent des erreurs et vérifient la précision et la vraisemblance des données de sortie une fois le traitement terminé. Exiger des utilisateurs qu'ils vérifient immédiatement la sortie de leur travail est le contrôle sur les sorties le plus basique et le plus essentiel car les utilisateurs disposent des meilleures connaissances sur le processus à ce moment donné. Trois totaux peuvent être rapprochés. L'auditeur peut générer manuellement des échantillons de total de contrôle et les comparer aux entrées et aux sorties du système. De la même manière, une comparaison automatisée des entrées et des sorties peut révéler des relations invraisemblables. Les formulaires de sortie prénumérotés, notamment les blancs de chèque, montrent les écarts de sortie de contrôle.

j. La conservation des enregistrements est un contrôle sur les sorties confirmé par la loi ou les règlements, en particulier pour les enregistrements financiers. D'autres enregistrements peuvent être stockés de manière électronique. Les procédures de sauvegarde des données peuvent assurer leur sécurité. Voici les contrôles sur les sorties :

1) Ces procédures sont exécutées à la fin du traitement afin de s'assurer que toutes les transactions que l'utilisateur s'attendait à traiter ont bien été traitées.
   a) Les **listes d'erreurs**. Toutes les transactions rejetées par le système sont enregistrées et distribuées au service approprié pour résolution. Les auditeurs vérifient que les erreurs sont suivies sans dépasser les limites de retard et que les rapports corrigés sont à nouveau soumis.
   b) Les **documents de référence**. Lorsque les systèmes sont interrompus, ces journaux montrent ce qui était en mémoire au moment de l'interruption.
   c) Les **contrôles de mise en file d'attente**. La mise en file d'attente est une allocation de mémoire temporaire à une sortie système. Ces contrôles régulent les méthodes de mise en file d'attente des données.

d) Les **documents de travail**. Les enregistrements légaux, notamment les chèques, les factures ou les certificats de stock, sont protégés. Il s'agit de preuves d'audit qui peuvent détecter si les entrées correspondent réellement aux sorties. Le double dépôt ou nécessité que deux personnes accèdent aux enregistrements est utilisé pour les obligations, les chèques ou les paies.

e) **Rapports.** Les contrôles de rapport incluent la vérification que les rapports sont précis, aussi simples que possible, opportuns, agrégés à un niveau significatif et que les données sensibles sont sécurisées à l'aide de contrôles de distribution.

f) Les **listes de contrôles** assurent la réception de tous les rapports planifiés et les listes de rapports récapitulent les rapports traités par lots. Les rapports sensibles doivent être déchiquetés.

g) **Rapports d'exception** En mettant en évidence uniquement les données extraordinaires, les rapports d'exception liés à la sortie doivent aider les responsables à déterminer la source d'erreur (erreur humaine, erreur de traitement, etc.).

h) **Les relevés de transactions.** Chaque action effectuée dans l'application est enregistrée avec la date, l'heure et l'ID utilisés lorsque l'action a été effectuée.

i) **Nombre d'enregistrement.** Le nombre total d'enregistrements traités par le système est comparé au nombre d'enregistrements que l'utilisateur s'attendait à voir traités.

j) **Totaux de contrôle d'exécution à exécution.** Le nouveau solde financier doit être la somme de l'ancien solde et de l'activité qui vient d'être traitée.

k. Les **contrôles d'intégrité** surveillent les données au fur et à mesure de leur traitement et lors de leur stockage pour vérifier qu'elles restent cohérentes et exhaustives. Les dossiers spécifiques doivent être uniques ce qui signifie qu'ils ne doivent pas être dupliqués ou enregistrés sous un nom légèrement différent. Les contrôles d'intégrité sont appliqués à la base de données et au système de gestion de base de données (DBMS, « Database management system ») afin que ces contrôles varient selon le type de système de gestion de base de données utilisé. Les contrôles d'intégrité des bases de données relationnelles sont les suivants :

a) **Clés primaires uniques**. La clé primaire, ou identifiant pour une ligne de données spécifique, doit être unique; par exemple on comptera exactement un seul dossier pour un client XZ.

b) **Clés primaires complètes**. La clé primaire ne peut pas contenir de valeur nulle.

c) **Intégrité référentielle**. Lorsqu'une table de base de données (appelée relation) contient une référence à une colonne (appelé un tuple) dans la table ou dans une autre table, cette colonne doit être vérifiée pour qu'elle puisse exister.

l. La **gestion ou les pistes d'audit** fournissent un historique de tous les traitements de transactions, qui présente chaque étape, de l'interception à la conclusion. Cela permet à un auditeur de suivre une transaction en amont, de la sortie à sa source. Cela peut être utile lors de l'identification de la source d'erreur ou de fraude.

7.4 : ANALYSE DES DONNÉES

1. L'Institut des auditeurs internes définit **l'analyse des données (AD)** comme suit :

"Le processus par lequel les données sont identifiées, consolidées et vérifiées sur le plan de la qualité et présentées dans un format où l'analyse peut être effectuée dans le but d'identifier l'information utile qui soutient mieux la prise de décision de l'entreprise.

2. L'analyse des données implique des méthodologies et des procédures qualitatives et quantitatives pour extraire les données des sources de données et les inspecter (conformément à des exigences prédéterminées) en fonction du type de données pour faciliter le processus décisionnel.

a. Un **type de données** spécifie le type de valeur (texte, nombre, image, date, chaîne, etc.) et les méthodes mathématiques, relationnelles et non relationnelles ou logiques applicables qui peuvent être appliquées sans entraîner une erreur.

b. Les données sont traitées à l'aide d'outils analytiques et algorithmiques pour révéler des informations significatives.

3. Les entités à but lucratif, les entités sans but lucratif et les organismes gouvernementaux (fédéraux, étatiques et locaux) utilisent l'AD pour arriver à une conclusion fondée sur des preuves et un raisonnement afin de prendre des décisions bien étayées et de formuler des modèles de gestion solides.

a. Les organisations peuvent également utiliser l'analyse des activités pour écarter les plans et modèles stratégiques proposés qui ne seraient pas bénéfiques ou qui ne fonctionneraient pas pour l'organisation.

4. Les auditeurs internes utilisent l'AD pour évaluer les données opérationnelles, financières et autres afin d'identifier tout écart par rapport à la norme (p. ex. détection des anomalies, risques potentiels) et les possibilités d'amélioration ou d'avancement.

5. L'analyse des données comprend les cinq étapes suivantes :

a. **Définir les questions**

1) Identifier les buts et les objectifs de ce que l'organisation essaie d'atteindre.

a) Des indicateurs clés de performance (ICP) doivent être définis pour aider à mesurer si une organisation progresse vers ses buts et objectifs. Voici des exemples d'ICR :

i) Ratio de liquidité générale
ii) Marge bénéficiaire nette
iii) Écart budgétaire
iv) Ratio dette/capitaux propres
v) Taux d'erreurs de paiement

b) Des buts et des objectifs clairement définis aident l'équipe des TI à choisir la source technologique la plus appropriée pour l'analyse.

c) L'adoption précoce d'objectifs et d'indicateurs clés de performance aide à maintenir l'analyse sur la bonne voie et à éviter les analyses inutiles.

b. **Obtenir des données pertinentes** (communément appelées " **découverte d'information "**)

1) L'accès à toutes les données disponibles permet de

a) Une analyse précieuse,
b) Des corrélations plus précises,
c) l'élaboration de modèles d'analyse et de prévisions significatifs, et
d) Identification des idées réalisables.

c. **Nettoyer/normaliser les données**

1) Le nettoyage des données consiste, sans s'y limiter, à éliminer les informations inutiles et à identifier les données manquantes.

2) La gouvernance des données (dont il est question à la sous-unité 7.1) permet de s'assurer que les données sont exactes et utilisables.

3) La normalisation des données consiste à stocker chaque élément de données aussi peu de fois que nécessaire. Il en résulte une réduction des données et un renforcement de l'intégrité des données pour l'utilisation d'une finalité spécifique.

a) **L'intégrité** consiste à s'assurer que les données reflètent fidèlement les événements commerciaux qui les sous-tendent et que toute anomalie est corrigée.

d. **Analyser les données**

1) Au fur et à mesure que les données recueillies sont analysées, on peut déterminer si les données sont les données exactes dont on a besoin. La détermination comprend, sans toutefois s'y limiter,

a) Évaluer si des données supplémentaires sont nécessaires,
b) Collecte de données nouvelles et/ou différentes,
c) Réviser la question originale, et
d) Formuler des questions supplémentaires.

2) Les méthodes d'analyse des données en vérification interne comprennent les types d'applications suivants :
   a) **L'analyse descriptive** est la méthode la plus simple et la plus utilisée. Elle se concentre sur la communication des résultats réels.
   b) **L'analyse diagnostique** donne un aperçu de la raison pour laquelle certains résultats ont été obtenus.
   c) **L'analyse prédictive** consiste à appliquer des hypothèses aux données et à prédire les résultats futurs.
   d) **L'analyse prescriptive** se concentre sur ce qu'une organisation doit faire pour que les résultats futurs prévus se concrétisent.
   e) **La détection des anomalies** est utilisée pour identifier les schémas inhabituels ou les écarts par rapport à la norme ou aux résultats escomptés.
   f) **L'analyse de réseau** consiste à analyser les données et les statistiques du réseau pour trouver des modèles.
   g) **L'analyse de texte** implique l'utilisation d'algorithmes de text mining et de langage naturel pour trouver des motifs dans des textes non structurés.
3) En général, le personnel de vérification interne sélectionnera les données à retracer jusqu'aux documents à l'appui, comme les factures, les contrats et les paiements, et appliquera les procédures supplémentaires suivantes :
   a) Examiner et confirmer les détails des données sélectionnées.
   b) Analyser les constatations et déterminer la conformité ou la non-conformité à la politique.
   c) Analyser les résultats pour en vérifier l'exactitude.
   d) Identifier les contrôles internes nécessitant une amélioration ou, en l'absence de contrôles, aider à la création d'un contrôle.

e. **Communiquer les résultats**

1) Avant de publier la communication finale, l'auditeur interne doit discuter des conclusions et recommandations avec la direction appropriée lors d'une réunion de clôture.
   a) La discussion donne à la direction l'occasion de clarifier les choses et d'exprimer son point de vue.
   b) L'objectif premier d'une réunion de clôture est d'assurer l'exactitude de l'information utilisée par l'auditeur interne.
2) La visualisation des données ou les illustrations graphiques (p. ex., tableaux, graphiques, analyse de réseau, etc.), la répétition écrite (p. ex., résumés) et les listes détaillées (à puces ou numérotées) sont de bons moyens de mettre en valeur l'information.
   a) L'utilisation d'aides visuelles pour appuyer une discussion sur des points importants permet de retenir le plus d'information possible.
3) En règle générale, le langage doit être fondé sur des faits et neutre. Mais si l'objectif de l'auditeur interne est de persuader une personne d'accepter des recommandations, il faut utiliser des mots à connotation forte ou émotive.
   a) L'utilisation d'un mot trop fort ou d'un mot inapproprié pour le destinataire particulier peut induire une réponse indésirable. Par conséquent, le langage à haute connotation devrait être choisi avec soin pour plaire au destinataire spécifique.

6. Les grandes données sont un terme en évolution qui décrit toute quantité volumineuse de données structurées, semi-structurées ou non structurées susceptibles d'être exploitées à des fins d'information.

a. **Les données structurées** désignent les données ayant un niveau élevé d'organisation (c.-à-d. une base de données relationnelle).

b. **Les données semi-structurées** ne sont pas conformes à la structure formelle des modèles de données associés aux bases de données relationnelles ou à d'autres formes de tableaux de données, mais il existe certains aspects du formatage des enregistrements et des champs dans les données.

c. **Les données non structurées** font référence à l'information qui n'est pas organisée d'une manière prédéfinie (c.-à-d. des faits, des dates, des chiffres et des images comportant beaucoup de texte).

7. Les grandes données comprennent les informations recueillies sur les médias sociaux, les données provenant d'appareils connectés à Internet, les données machine, les vidéos et les enregistrements vocaux. L'information recueillie est convertie des données à faible densité en données à haute densité (données qui ont de la valeur).

8. Les grandes données sont souvent caractérisées par les "4 V".

a. **Volume**

1) Le terme "volume" est utilisé pour décrire la quantité extrême de données saisies au fil du temps.

a) Selon la quantité de données à capturer, le nombre de serveurs requis peut varier d'un seul serveur à des milliers.

2) Les capteurs en temps réel utilisés dans l'Internet des objets (IoT) sont devenus l'une des principales sources de données.

a) L'Internet des objets est le réseau de dispositifs informatiques interreliés, intégrés à des dispositifs physiques, tels que des véhicules, des appareils électroménagers et d'autres objets du quotidien. Celles-ci sont dotées de capteurs en temps réel et de la capacité de transférer des données sur un réseau sans nécessiter d'interaction d'homme à homme ou d'homme à ordinateur.

b. **Variété**

1) Les données existent dans une grande variété de types de fichiers.

b) Les types de fichiers de données structurés sont généralement gérés par le langage SQL (Structured Query Language), qui est utilisé pour gérer les bases de données relationnelles et effectuer diverses opérations sur les données qu'elles contiennent.

c) Les types de fichiers de données non structurés (c.-à-d. les données en continu provenant des capteurs, du texte, du son, des images et des vidéos) sont conservés par des bases de données non relationnelles (c.-à-d. NoSQL).

c. **Vitesse**

1) Le terme "vitesse" fait référence à la vitesse à laquelle les grandes données doivent être analysées.

a) Les analystes doivent avoir une compréhension détaillée des données disponibles et savoir quelle(s) réponse(s) ils recherchent.

b) La puissance de calcul nécessaire pour traiter rapidement d'énormes volumes et variétés de données peut submerger un ou plusieurs serveurs. Les organisations doivent appliquer une puissance de calcul adéquate aux grandes tâches de données pour atteindre la vitesse désirée.

c) Les entreprises hésitent à investir dans une vaste infrastructure de serveurs et de stockage qui ne pourrait être utilisée qu'occasionnellement pour accomplir de grandes tâches de données. En conséquence, le cloud computing est devenue la principale source d'hébergement de grands projets de données.

d. **Véracité**

1) Le terme "véracité" fait référence à la fiabilité des données (divergences inhérentes aux données collectées).

a) L'utilisateur peut-il se fier au fait que les données sont représentatives ?

9. Le "5e V"

a. De plus en plus d'entreprises utilisent de grandes données en raison de la **valeur de l'**information résultant de l'analyse des flux d'information importants et de l'identification des possibilités d'amélioration.

1) L'utilisation de grandes données n'a de valeur que dans la mesure où les résultats commerciaux qu'elle permet d'obtenir le sont. C'est la façon dont les entreprises utilisent les

données qui leur permet de reconnaître pleinement leur valeur réelle et leur potentiel d'amélioration de leurs capacités décisionnelles et de leurs résultats positifs.

a) **Valeur basée sur le volume.** Plus les entreprises disposent de données sur leurs clients, tant récentes qu'historiques, plus elles ont d'informations. Cela permet de prendre de meilleures décisions concernant l'acquisition, la fidélisation, l'augmentation et la gestion de ces relations avec la clientèle.

b) **Valeur basée sur la variété.** À l'ère du numérique, la capacité d'acquérir et d'analyser des données variées est extrêmement précieuse. Cela permet d'acquérir une connaissance approfondie de l'élaboration et de la personnalisation des plates-formes clients afin que les entreprises soient plus engagées et plus conscientes des besoins et des attentes de leurs clients.

c) **Valeur basée sur la vitesse.** Plus les entreprises traitent rapidement les données, plus elles auront de temps pour poser les bonnes questions et chercher des réponses. Les capacités d'analyse rapide fournissent aux entreprises les bonnes données à temps pour atteindre leurs objectifs de gestion de la relation client.

d) **Valeur basée sur la véracité.** Une fois les données validées, elles se transforment en "données intelligentes". La collecte de grandes quantités de statistiques et de chiffres n'a que peu de valeur si on ne peut pas s'y fier et les utiliser.

10. Les grandes données utilisent des statistiques et des concepts inductifs à partir de l'identification non linéaire du système (c.-à-d. que la production n'est pas directement proportionnelle à l'entrée) pour déduire des lois à partir de grands ensembles de données afin de révéler des relations et des dépendances ou de prévoir des résultats et des comportements.

a. Elles peuvent être utilisées pour analyser des données afin de déterminer les possibilités qui comprennent, sans s'y limiter : (1) la réduction des coûts ; (2) des délais ; (3) le développement et l'optimisation des nouveaux produits, (4) les nouveaux clients.

b. Les grands outils d'analyse de données complètent les pièces manquantes par la **fusion de données**, qui est le processus d'intégration de données et de connaissances représentant le même objet du monde réel dans une représentation cohérente, précise et utile.

11. Technologies clés

a. **Gestion des données.** Les données doivent être de haute qualité et bien gérées avant de pouvoir être analysées de façon fiable. Ainsi, les entreprises doivent

1) Établir des processus reproductibles pour établir et maintenir des normes de qualité des données.

2) Établir un programme de gestion des données de base.

b. **L'exploration de données** examine de grandes quantités de données pour découvrir des modèles dans les données.

1) L'exploration de données passe au crible tous les bruits chaotiques et répétitifs des données, identifie ce qui est pertinent, utilise cette information pour évaluer les résultats probables, puis accélère le rythme de la prise de décisions éclairées.

c. **Hadoop** est une infrastructure logicielle open source qui stocke de grandes quantités de données et exécute des applications sur des grappes de matériel standard.

d. **Analyse en mémoire**

1) Analyse les données de la mémoire système au lieu d'une mémoire secondaire

2) Obtient des résultats immédiats en supprimant les délais de préparation des données et de traitement analytique.

3) Permet des scénarios analytiques itératifs et interactifs plus efficaces

e. **L'analyse prédictive** utilise des données, des algorithmes statistiques et des techniques d'apprentissage machine pour déterminer la probabilité de résultats futurs en fonction des données historiques.

f. **Exploration de texte**

1) Analyser les données textuelles provenant du Web, des champs de commentaires, des livres et d'autres sources textuelles au moyen de l'apprentissage automatique ou de la technologie de traitement du langage naturel.
2) Identifie de nouveaux sujets et de nouvelles relations à long terme.

12. Un sondage sur l'analyse des données et le leadership mené en 2015 par « Institute of Internal Auditors Research Foundation (IIARF) » et Grant Thornton (GT) a identifié ce que les professionnels de l'audit interne reconnaissent comme les avantages de l'AD. Les résultats de l'enquête sont les suivants :

Le processus de vérification est rationalisé	56 %
Le temps de travail sur le terrain est réduit	50 %
Les transactions frauduleuses sont identifiées	45 %
L'étendue de l'audit est plus uniforme	40 %
Un plus grand nombre d'audits peuvent être effectués	28 %

a. En outre, l'enquête a révélé ce qui suit en ce qui concerne les principales utilisations de l'AD :

Analyse des tendances	72 %
Surveillance de la conformité	56 %
Détection de la fraude	54 %
Évaluation de la performance de l'entreprise / de l'exploitation	48 %
Visualisation des données	40 %
Analyse prédictive	17 %
Modélisation	12 %